Actividad N°7 — Trazabilidad y plan de respuesta

Nombre: Grupo MTG Companion
Integrantes: Vicente Fuentes, Tomás Rodriguez, Tomás Solano
Fecha: 7 nov 2026
Proyecto: MTG Companion, una app de compraventa de cartas Magic (`apps/`), con backend NestJS + Prisma + PostgreSQL y cliente Ionic/React
Repositorio: https://github.com/inzenfenix/MTGCompanion_TCG · tarea: issue #151 · fila O17 de `ROADMAP.md`
Insumos: inventario del Hito 1 (`hito1/`) y los controles ya implementados: seudonimización y RBAC (Actividad N°4), auditoría encadenada, alertas y plan de incidentes (Actividad N°5), derechos (Actividad N°6)
Plan de respuesta: documento propio, `PLAN_RESPUESTA_INCIDENTES.md`

La Actividad N°5 dejó un registro de auditoría seudonimizado, encadenado con HMAC y de solo agregar, más seis reglas de detección. Al revisarlo contra esta actividad aparecieron tres vacíos:

1. **Muchos accesos a datos personales no dejaban rastro:**
   - ver el detalle de una compra o su comprobante (alias y monto de la contraparte);
   - el listado de cuentas del ADMIN;
   - el cálculo de distancias del Bazar, que lee la **ubicación** de los vendedores;
   - el registro de cuentas, el 2FA, las compras y las ofertas.
2. **El catálogo de eventos solo existía en un informe**, no en el código, así que nada impedía agregar una operación sin registrarla.
3. **Las alertas eran genéricas** (fuerza bruta, sondeo de rutas). Ninguna miraba los riesgos propios de un mercado con ubicación y transacciones.

Esta entrega cierra los tres y agrega una herramienta para **reconstruir un incidente desde el registro**. La herramienta se probó con un incidente simulado (§6).

Marco legal. Ley 19.628 en el texto de la Ley 21.719, vigente desde el 01-12-2026: arts. 14 quinquies (deber de seguridad) y 14 sexies (reporte de vulneraciones). Ambos verificados contra el texto de la BCN.

---

1. Qué se audita y qué campos tiene cada registro

1.1 Catálogo de eventos, en el código

`audit-events.ts` es la definición de *qué se audita*: **48 acciones** más la familia `denied <MÉTODO> <ruta>` (denegaciones de RBAC). Para cada acción indica:

- la categoría;
- si es una lectura (`READ`), una escritura (`WRITE`), una autenticación (`AUTH`) o un control (`CONTROL`);
- **qué categorías de datos personales del inventario toca**;
- qué lleva en los campos variables.

El catálogo completo, tal como lo cargó el backend compilado, está en `01_catalogo_eventos.txt`.

Categoría	Eventos (resumen)	Datos personales que tocan
AUTH	`auth.login` (correcto, fallido, bloqueado), `auth.2fa`, `auth.step-up`, **`auth.2fa.enable`**, **`auth.2fa.disable`**	credenciales
ACCOUNT	**`account.register`**, **`account.location.update`**, **`account.location.erase`**	identificación, credenciales, geolocalización
CONSENT	`consent.grant`, `consent.revoke`	preferencias
RIGHTS	`data.export`, `data.rectify`, `data.erase`, `data.object`, `data.block`, `data.public-request` …	todas las del titular
ACCESS (nuevo)	**`access.transaction.read`**, **`access.transaction.list`**, **`access.receipt.read`**, **`access.profile.read`**, **`access.location.distance`**	transacciones, identificación, geolocalización
MARKET (nuevo)	**`market.card.create`**, **`market.card.delete`**, **`market.offer.place`**, **`market.transaction.create`**, **`market.cash.confirm`**	colección, transacciones
STAFF	**`admin.users.list`**, `support.transactions.read`, `admin.pseudonym.resolve`, `admin.audit.read`, **`admin.incident.timeline`** …	identificación, transacciones, registro
SECURITY / SYSTEM	`security.alert.*`, `security.containment.*`, `security.recovery.enable`, `incident.snapshot`, `audit.retention.purge`, `denied` …	—

En **negrita** van los eventos nuevos de esta entrega.

El catálogo se hace cumplir de dos formas:

- `audit-events.spec.ts` **escanea el código fuente** y falla si alguna acción que se registra no está catalogada.
- La e2e y la evidencia comprueban que **toda fila escrita en la BD** corresponde a una acción del catálogo (resultado: `true`, `02`).

1.2 Campos de cada registro

Todos los eventos tienen los mismos campos (tabla `audit_logs`). Lo único que cambia por evento es lo que va en `resourceType`, `resourceRef` y `reason`, y eso lo describe el catálogo.

Campo	Contenido	Ejemplo real
`id`, `seq`	Identificador y número secuencial (orden total)	`seq 69`
`createdAt`	Fecha y hora UTC, con milisegundos	`02:11:51.963`
`actorPseudonym`, `actorRole`	**Quién**: seudónimo HMAC (`u_…`), `system` o `anonymous`, y su rol en ese momento	`u_55c28db9…`, `USER`
`action`	**Qué operación** (del catálogo)	`access.transaction.read`
`targetPseudonym`	**De quién son los datos** (seudónimo)	la contraparte de la compra
`resourceType`, `resourceRef`	**Sobre qué recurso**: tipo e id interno, nunca una copia del dato	`transaction 0ee0e01b-…`

Campo	Contenido	Ejemplo real
`reason`	Código o conteo: motivo de denegación, nombres de campos, motivo declarado por el personal	`forbidden`, `n=1`, `sellers=3;new-position`, `email`
`outcome`	`ALLOWED`, `DENIED` o `FAILED`	`DENIED`
`prevHash`, `hash`	Eslabón de la cadena de integridad (HMAC-SHA256)	—

Lo que nunca se guarda:

- valores de datos personales: correo, alias, ubicación, montos de terceros, contenido de una exportación;
- contraseñas y tokens;
- IP o agente de usuario.

`AuditService.record` seudonimiza todo lo que entra y además enmascara cualquier correo o token que se cuele en `reason`.

---

2. Registro de accesos y operaciones sobre datos personales

2.1 Cómo se implementó

El decorador `@AuditAccess` se pone en cada ruta que lee o cambia datos personales. Lo procesa un **interceptor global** (`audit-access.interceptor.ts`), que no hace nada en las rutas sin decorador. Así el registro no depende de que cada servicio "se acuerde" de llamar a la auditoría.

Resultado de la ruta	Lo que se registra
Responde normalmente	`ALLOWED`, con el id del recurso y **de quién son los datos** (por ejemplo, la contraparte de una compra)
401 / 403 / 404 / 409 / 400 lanzado por la ruta	`DENIED`, con el motivo (`forbidden`, `not-found`…) y **sin** afectado, para no revelar de quién era el recurso
Error interno (5xx)	Nada (no es una decisión de acceso)

La fila se escribe **antes** de que la respuesta salga, así que existe cuando el cliente recibe el dato.

Ruta	Evento
`GET /transactions/:id` · `/:id/receipt` · `GET /transactions`	`access.transaction.read` · `access.receipt.read` · `access.transaction.list`
`GET /users/:id` (perfil público)	`access.profile.read`
`GET /cards?q=…&lat=…&lng=…` (Bazar con distancia)	`access.location.distance`
`GET /admin/users`	`admin.users.list`
`POST /users/register` · `PATCH`/`DELETE /users/me/location` · `POST /auth/2fa/enable`/`disable`	`account.*`, `auth.2fa.*`

Ruta	Evento
`POST /cards` · `DELETE /cards/:id` · `POST /cards/:id/offers` · `POST /transactions` · `POST /transactions/:id/confirm-cash-received`	`market.*`

Cambio de minimización en el Bazar. La distancia a cada vendedor se calcula con su ubicación, que es una categoría especial (art. 16 sexies). Antes se calculaba para cualquiera, sin sesión. Ahora:

- **solo se calcula para usuarios con sesión**, así que cada lectura de ubicaciones queda atribuida a una cuenta;
- se registra **cuántas distancias** se calcularon (`sellers=N`), nunca las coordenadas del buscador ni las de los vendedores.

La app ya exige sesión, así que su comportamiento no cambia.

2.2 Evidencia

Las operaciones de la tabla siguiente se ejecutaron sobre el backend compilado (`02_registro_accesos.txt`). Las etiquetas entre paréntesis las agrega el script de evidencia para poder leer el resultado; **no están en la BD**.

```
seq  actor               rol      acción                     afectado           recurso
motivo                resultado
 11  u_574e51fe…(vale)   USER     account.location.update    —                  user
ALLOWED
 12  u_134ef485…(bruno)  USER     access.transaction.read    u_574e51fe…(vale)
transaction 22d834e6…                          ALLOWED
 13  u_574e51fe…(vale)   USER     access.receipt.read        u_134ef485…(bruno)
transaction 22d834e6…                          ALLOWED
 16  u_134ef485…(bruno)  USER     access.location.distance   —                  card-
search            sellers=1;new-position ALLOWED
 17  u_3909f316…(admin)  ADMIN    admin.users.list           —                  user
n=4                   ALLOWED
 18  u_e928aa86…(soporte) SUPPORT  support.transactions.read  u_574e51fe…(vale)
Reclamo de pago del…   ALLOWED
 21  u_089957cc…(intruso) USER    access.transaction.read    —
transaction 22d834e6…  forbidden              DENIED
 22  u_089957cc…(intruso) USER    access.receipt.read        —
transaction 81eaf5a6…  not-found              DENIED
```

Comprobaciones sobre todas las filas del registro:

¿Aparece en alguna fila…?	Resultado
un correo	`false`
un id real de usuario	`false`
un alias	`false`
una coordenada	`false`
una fila sin encadenar	ninguna (todas tienen `hash`)
una acción fuera del catálogo	ninguna

---

3. Protección de los registros

3.1 Acceso restringido

Quién	Leer el registro (`GET /admin/audit-logs`)	Reconstruir un incidente	Verificar la cadena
USER	✗ 403 (auditado)	✗ 403	✗
SUPPORT	✗ 403 (auditado)	✗ 403	✗
ADMIN	✓, y **leerlo también se audita** (`admin.audit.read` , `admin.incident.timeline`)	✓	✓

Reglas que completan la tabla:

- **Leer el registro no identifica a nadie.** Para re-identificar un seudónimo hay que usar `POST /admin/pseudonyms/resolve`: solo ADMIN, con motivo obligatorio y auditado.
- **Desde esta entrega, re-identificar en masa levanta una alerta** (`admin.reidentification.burst` , §4).
- **No existe ningún endpoint** que edite o borre registros.

En la base de datos (`03_proteccion.txt`):

- `UPDATE` , `DELETE` y `TRUNCATE` sobre `audit_logs` fallan **incluso para el dueño de la tabla**: `audit_logs is append-only (… rejected)` .
- Cada fila está encadenada con HMAC, con una llave que vive solo en el proceso del backend. Editar una fila (desactivando antes el trigger) rompe la cadena, y la verificación lo detecta y levanta `audit.chain.broken` . Eso se demostró en la Actividad N°5.
- La reconstrucción de incidentes **verifica la cadena antes de mostrar nada**. Si está rota, marca el resultado como no confiable desde `brokenAt` en vez de ocultarlo.

3.2 Plazo de conservación

	Valor	Quién lo hace cumplir
Plazo	**730 días** (`AUDIT_RETENTION_DAYS`)	`purge-expired-data` , al arrancar el contenedor
Mínimo	**365 días**, sin importar lo que pida la sesión	El trigger de la BD: `GREATEST(…, 365)`
Quién puede borrar	Solo una transacción que active `app.audit_retention_purge` , y solo filas más antiguas que el plazo	El trigger
Constancia	La purga queda registrada en la cadena (`audit.retention.purge`)	`purge-expired-data`

Por qué 730 días. Alcanzan para investigar incidentes detectados tarde y para responder reclamos ante la Agencia. Son menos que los 6 años tributarios porque el registro no es contable. Las lecturas nuevas (`access.*`) siguen el mismo plazo: son las que permiten responder "¿quién vio mis datos?".

Demostrado en la evidencia, con dos filas sintéticas antiguas insertadas fuera de la cadena:

Intento	Resultado
Purgar con la marca, sobre una fila de hoy	**Rechazado**
Purgar pidiendo un plazo de 30 días, sobre la fila de 100 días	**Rechazado** (el piso es 365)
Purgar con plazo de 365 días, sobre la fila de 400 días	**Permitido**; queda solo la de 100 días

---

4. Alertas de acceso anómalo propias del sistema

Las seis reglas de la Actividad N°5 siguen activas. Esta entrega agrega **cuatro reglas pensadas para los riesgos de este mercado** (`detection-rules.ts`). Se evalúan sobre cada fila nueva del registro, contando por seudónimo, sin IP ni correo.

Regla	Qué la dispara	Por qué es propia de este sistema	Severidad	Contención automática
`bazaar.location.triangulation`	≥ 5 búsquedas con distancia desde **celdas de ~1 km distintas** en 10 min	El Bazar responde la distancia a cada vendedor. Con 3 o más puntos se puede triangular dónde vive. Quien busca desde su teléfono no salta entre 5 celdas en 10 minutos	ALTA	Revocar sesiones
`account.takeover.sequence`	**Cambio del correo** seguido de **exportación completa o supresión** en < 1 h	Es el patrón de toma de cuenta que habilitan los derechos de la Actividad N°6: quedarse con el correo y llevarse o borrar los datos	ALTA	Revocar sesiones
`transactions.enumeration`	≥ 5 lecturas **denegadas** de transacciones, comprobantes o perfiles ajenos o inexistentes en 10 min	Es el sondeo de ids (IDOR) para leer compras ajenas: el riesgo que la Actividad N°4 corrigió en el código y que ahora además se vigila	MEDIA	—
`admin.reidentification.burst`	≥ 5 re-identificaciones de seudónimos por un ADMIN en 1 h	Deshace a escala la seudonimización de la Actividad N°4: abuso interno o cuenta de personal comprometida	ALTA	— (se revisa a mano; ver el plan)

Detalles de implementación:

- **Triangulación sin guardar la ubicación del buscador.** Un rastreador **en memoria**, por buscador y por 10 minutos (`search-position-tracker.ts`), marca `new-position` cuando la búsqueda viene de una celda que no usó en la ventana. La posición nunca llega a la BD ni al registro.
- **Regla de secuencia.** `account.takeover.sequence` se dispara con la exportación, pero **cuenta un evento anterior distinto**: cambios de correo (`data.rectify` con `email` en `reason`). Para eso las reglas aceptan ahora un filtro por `reason`.

- **Revocación en milisegundos.** Se encontró y corrigió un hueco al probar estas alertas. La revocación comparaba el `iat` del token, que está en segundos enteros. El token con el que el atacante acababa de disparar la alerta casi siempre tenía el mismo segundo que la revocación, y **sobrevivía**. Ahora el token lleva su hora de emisión en milisegundos (`iatMs`) y la contención lo corta de inmediato (demostrado en §6).

Evidencia (`04_alertas.txt`): cada regla se disparó con su caso y **no** se disparó en un caso de control.

Caso	Alerta
curioso busca desde 5 celdas distintas	`bazaar.location.triangulation` ALTA; su token siguiente da **401**
bruno busca 6 veces desde su casa (misma celda)	**ninguna**
intruso acumula 5 lecturas denegadas	`transactions.enumeration` MEDIA
Un ADMIN re-identifica 5 seudónimos sin caso abierto	`admin.reidentification.burst` ALTA; su sesión sigue activa: decide un humano
bruno exporta sus datos sin haber cambiado el correo	**ninguna**
Toma de la cuenta de *marta*	`account.takeover.sequence` ALTA (§6)

Cada alerta llegó además por correo al buzón de seguridad, por ejemplo `[HIGH] Alerta de seguridad: bazaar.location.triangulation` (`06_correos_alertas.txt`).

---

5. Plan de respuesta a incidentes

El plan es un documento propio y versionado: `PLAN_RESPUESTA_INCIDENTES.md` (v2.0). Reemplaza el §4 de la Actividad N°5. Resumen:

Pide la actividad	Dónde está en el plan
Criterios	§1: qué es un incidente (art. 14 sexies), cómo se detecta y los 5 niveles (`OPEN` → `INVESTIGATING` → `CONFIRMED` / `DISMISSED` → `CLOSED`). §2: **severidad inicial de cada una de las 11 alertas** y **severidad confirmada por impacto**, decidida con la reconstrucción: cuántas cuentas, qué categorías, acceso real o solo intentos
Responsables	§3: roles con titular y suplente (líder, desarrollo, administración, comunicación), **matriz RACI**, doble firma para toda notificación externa, y apartar a un integrante si el incidente lo involucra
Fases	§5: preparación → detección y análisis (preservar con `incident:snapshot` **antes** de tocar nada, luego reconstruir con `incident:timeline`) → contención (de menor a mayor, nada se borra) → erradicación y recuperación (con lista de comprobación) → notificación → lecciones aprendidas y cierre. Cada fase con plazos
Contenido de la notificación	§5.5: a quién y cuándo. **Plantilla A para la Agencia**, con los puntos que el art. 14 sexies exige registrar. **Plantilla B para cada titular**, en lenguaje claro: qué datos, consecuencias posibles, medidas, recomendaciones y contacto
(además)	§6: **guía de actuación por cada alerta propia**: primeras preguntas, contención y si corresponde notificar

Dos decisiones del plan basadas en la ley:

- **Transacciones → aviso a los titulares obligatorio.** Son "datos relativos a obligaciones de carácter … comercial", así que su filtración obliga a avisar también a los titulares (art. 14 sexies, inciso 3°).
- **Ubicación → aviso por decisión propia.** Se verificó que **no** es "dato sensible" según el art. 2 g). Aun así, el plan avisa a los titulares si se filtra, porque revela dónde vive un vendedor.

---

6. Simulación de un incidente y reconstrucción desde los registros

6.1 Escenario

Toma de la cuenta de *marta*, una vendedora, con una contraseña filtrada en otro sitio. El "atacante" sigue un **guion** que el script de evidencia anota paso a paso. Después, **sin mirar el guion**, el ADMIN de turno sigue el plan y reconstruye el incidente **solo desde el registro**. Al final se comparan ambos. Evidencia: `05_simulacion_incidente.txt`.

Fase del ataque	Qué hizo
1. Entrar	2 contraseñas incorrectas y luego la correcta
2. Mirar	Lista las ventas de *marta*, abre la venta a *pedro* (ve su alias y el monto), mira el perfil de *pedro*
3. Sondear	5 intentos de leer compras ajenas o inexistentes (403/404) → **alerta `transactions.enumeration`**
4. Quedarse con la cuenta	Reautenticación con la contraseña filtrada; cambia el correo de la cuenta al suyo; vuelve a entrar
5. Llevarse los datos	Exportación completa → **alerta `account.takeover.sequence`** + **sesiones revocadas**
6. Volver a intentar	Su token da **401**

Mientras tanto, el sistema avisó al buzón de seguridad y **a la dirección anterior de *marta*** ("El correo de tu cuenta MTG Companion cambió"). Así se entera la titular real.

6.2 Respuesta, siguiendo el plan

1. **Triage:** la alerta pasa a `INVESTIGATING`, con una nota.
2. **Preservar:** `incident:snapshot` (manifiesto SHA-256), **antes** de cualquier contención manual.
3. **Reconstruir:** `GET /admin/security/incidents/:alertId/timeline?format=md`. Resultado en `05b_linea_de_tiempo_api.md`.
4. **Confirmar y contener:** la alerta pasa a `CONFIRMED` y se deshabilita la cuenta mientras se le devuelve a su titular.
5. **Identificar a quién notificar:** re-identificación de *pedro*, con motivo `INC-1: notificar al comprador afectado (art. 14 sexies)` y auditada.
6. **Reconstruir de nuevo, sin la API:** `npm run incident:timeline -- --alert <id>`, el script que se usa si la API está caída o comprometida. Resultado en `05c_linea_de_tiempo_offline.md`.

6.3 Lo que reconstruyó el registro

Extracto de la reconstrucción offline. Los nombres entre paréntesis los agrega el script de evidencia.

```
- Cadena de integridad: OK (88 filas, seq 1–90)
- Eventos: 27 (7 denegados o fallidos)
- Otras cuentas afectadas: u_a57538b47fcd (pedro) (2: access.profile.read,
access.transaction.read)

| seq | hora (UTC)   | fase                                | acción
| afectado      | motivo        | resultado |
| 65  | 02:11:51.608 | Acceso a la cuenta                  | auth.login
| –             | bad-password  | FAILED  |
| 66  | 02:11:51.783 | Acceso a la cuenta                  | auth.login
| –             | bad-password  | FAILED  |
| 67  | 02:11:51.958 | Acceso a la cuenta                  | auth.login
| –             |               | ALLOWED |
| 68  | 02:11:51.961 | Acceso a datos personales           | access.transaction.list
| –             | n=1           | ALLOWED |
| 69  | 02:11:51.963 | Acceso a datos personales           | access.transaction.read
| (pedro)       |               | ALLOWED |
| 70  | 02:11:51.965 | Acceso a datos personales           | access.profile.read
| (pedro)       |               | ALLOWED |
| 71–75 | …          | Reconocimiento (intentos denegados) | access.transaction.read /
receipt    | –             | forbidden / not-found | DENIED |
| 76  | 02:11:51.977 | Detección                           | security.alert.raised
| (marta)       | transactions.enumeration (MEDIUM) | ALLOWED |
| 77  | 02:11:52.193 | Acceso a la cuenta                  | auth.step-up
| –             | password      | ALLOWED |
| 78  | 02:11:52.202 | Modificación                        | data.rectify
| (marta)       | email         | ALLOWED |
| 79  | 02:11:52.377 | Acceso a la cuenta                  | auth.login
| –             |               | ALLOWED |
| 81  | 02:11:52.560 | Exfiltración o destrucción          | data.export
| (marta)       |               | ALLOWED |
| 82  | 02:11:52.563 | Detección                           | security.alert.raised
| (marta)       | account.takeover.sequence (HIGH) | ALLOWED |
| 83  | 02:11:52.607 | Contención                          | security.containment.revoke-
sessions | (marta)       |               | ALLOWED |
| 84–89 | …          | Contención (ADMIN)                  | alert.update,
containment.disable    | (marta)       | INC-1: …      | ALLOWED |
```

6.4 Comprobación: guion vs. reconstrucción

#	Paso del guion (lo que hizo el atacante)	Acción esperada	Esperado	Encontrado en el registro
1	2 contraseñas incorrectas	`auth.login` FAILED	2	2 ✔
2	Login con la contraseña filtrada	`auth.login` ALLOWED	1	1 ✔
3	Lista las transacciones de *marta*	`access.transaction.list`	1	1 ✔
4	Abre la venta a *pedro*	`access.transaction.read`	1	1 ✔
5	Mira el perfil de *pedro*	`access.profile.read`	1	1 ✔
6	Sondea 5 transacciones ajenas o inexistentes	`access.*` DENIED	5	5 ✔
7	Reautenticación	`auth.step-up`	1	1 ✔
8	Cambia el correo	`data.rectify` (`email`)	1	1 ✔

#	Paso del guion (lo que hizo el atacante)	Acción esperada	Esperado	Encontrado en el registro
9	Vuelve a entrar	`auth.login`	1	1 ✔
10	Exporta los datos	`data.export`	1	1 ✔

Resultado: 10 de 10 pasos reconstruidos, en el mismo orden, con la cadena verificada. La API y el script offline coinciden.

Con eso, el registro **sí responde** las preguntas del plan:

Pregunta	Respuesta del registro
¿Quién?	El seudónimo de la cuenta tomada; se re-identifica solo para notificar
¿Cuándo?	Entre 02:11:51.6 y 02:11:52.6, con detección y contención automática en el mismo segundo
¿Qué hizo?	Las 7 fases, en orden
¿Llegó a datos?	Sí: lecturas `ALLOWED` y una exportación `ALLOWED`
¿De quién?	*marta* y su comprador *pedro*, el único tercero cuyos datos vio
¿Qué categorías de datos?	Identificación y transacciones como mínimo. La lista de la reconstrucción es una **cota superior**, porque toma del catálogo todo lo que cada operación *puede* tocar; el análisis la ajusta
¿Hay que notificar?	Sí, a la Agencia y a ambos titulares: hubo **transacciones** comprometidas (plan §5.5)

Lo que el registro no puede decir, por diseño: la contraseña usada, la IP, el correo nuevo del atacante (se obtiene de la cuenta, que es el dato vigente) y el contenido exportado. Es el costo de la minimización, y el plan lo asume.

---

7. Pruebas

Suite	Resultado	Nota
Unitarias (`07a`)	**176/176**	Nuevas: catálogo (escaneo del código), reconstrucción por fases, rastreador de posiciones, las 4 reglas
e2e (`07b`)	**197/200**	Nueva suite `traceability` 17/17. Las 3 que fallan son de `catalog` y necesitan el catálogo de Scryfall, que no está en este equipo (igual que en las Actividades 4 a 6)
App (`07c`)	**108/109**	La que falla necesita el modelo ONNX, que no está en este equipo. La app no cambió

Regenerar la evidencia:

```
cd apps/backend && npm run build
node test/evidence/actividad7.mjs ../../docs/security/evidencia/actividad7
```

---

8. Limitaciones

- **TLS (O5/I6) sigue pendiente.** Es el mayor riesgo: los tokens y las exportaciones viajan sin cifrar en el despliegue actual.

- **Rol `mtg_app` sin conectar al despliegue (O14).** Hasta conectarlo, el dueño de la BD puede desactivar el trigger. La cadena lo **detecta**, pero no lo **impide**.
- **El rastreador de posiciones vive en memoria.** Un reinicio lo vacía, lo que solo retrasa la detección una ventana de 10 minutos. Con más de una instancia del backend habría que llevarlo a un almacén compartido.
- **Sin IP.** Un ataque distribuido entre muchas cuentas solo se ve por volumen. La defensa queda para la capa de red (WAF), que no está construida.
- **Las categorías de la reconstrucción son una cota superior** (§6.4) y el análisis humano las ajusta.
- **Umbrales iniciales.** Son conservadores y se ajustan en "lecciones aprendidas".
- **No verificado aquí:** despliegue en AWS, entrega real de correos por SES y `terraform validate`.

Referencias

- Ley N° 19.628, texto modificado por la Ley N° 21.719 (D.O. 13-12-2024), vigente desde el 01-12-2026: arts. 2 g), 14 quinquies, 14 sexies y 16 sexies. BCN, https://www.bcn.cl/leychile/navegar?idNorma=141599
- Reglamento (UE) 2016/679 (RGPD), art. 33, solo como referencia de buena práctica para el plazo interno de 72 h.
- Ley N° 21.459 (delitos informáticos).
- Grupo MTG Companion: Hito 1, Actividades N°4, N°5 y N°6, y el plan de respuesta, en `docs/security/`.